

TimeSheets: Threat Report



[Your Name]
[Date]

How to Use this Template

- We have provided these slides as a guide to ensure you submit all the required components to complete your project successfully.
- When presenting your project, remember that these slides are merely a guide. We strongly encourage you to embrace your creative freedom and make changes that reflect your unique vision as long as the required information is present.
- You can add slides to the template when your answers or screenshots do not fit on the previously provided pages.
- Delete this and the next slide before submitting your project.
- **Remember to add your name and the date to the cover page.**

Purpose of this Report

This is a threat model report for [TimeSheets](#). The report will describe the threats facing TimeSheets. The model will cover the following:

- Threat Assessment
 - Scoping out Asset Inventory
 - Architecture Audit
 - Threat Model Diagram
 - Threats to the Organization
 - Identifying Threat Actors
- Vulnerability Analysis
- Risk Analysis
- Mitigation Plan



Section One: Initial Threat Assessment

Completed Asset Inventory

Components and Functions

- **TimeSheets Web Server:** The web server's primary role is to serve static content to a requesting client through the http protocol.
- **TimeSheets Application Server:** The application server handles all the business logic process and serves dynamic content.
- **TimeSheetsDB:** The database server stores employee data and will be queried from the application server.
- **AuthDB:** Stores user authentication data (credentials) and will be queried from the application server.

Overview of Application Functionality

TimeSheets is used by employees to track their hours worked. Users will login to the TimeSheets application from their device.

Data Flow

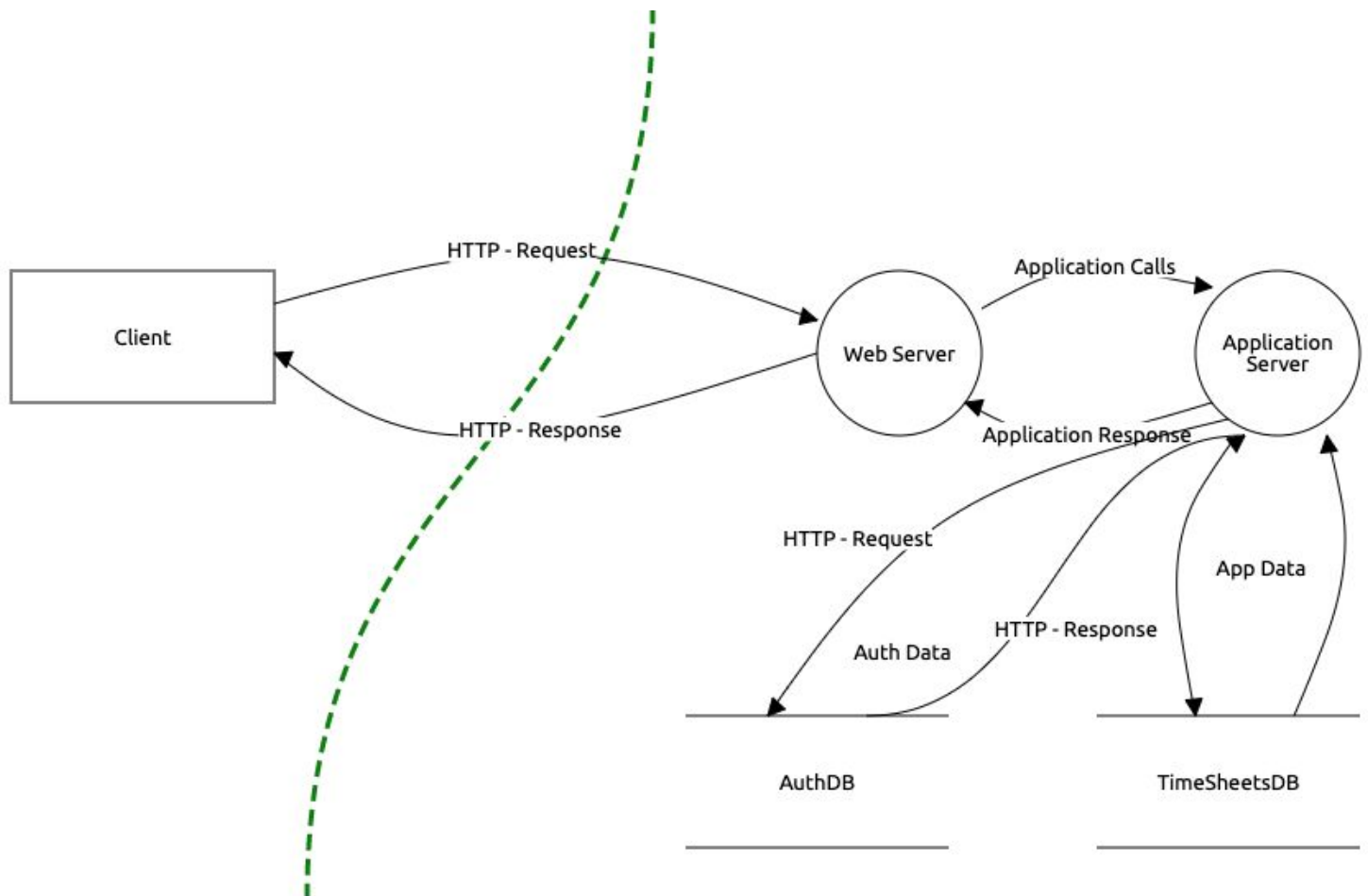
Request is generated from the client via the Internet. The request arrives at the TimeSheets web server which serves static content to the user (HTML, images, etc). Dynamic data is retrieved from the database and served to the client.

Completed Architecture Audit

Flaws

- There is a lack of encryption at rest - database servers are storing data on unencrypted disks.
- There is lack of redundancy.
- There is no firewall that is filtering traffic coming from the Internet

Completed Threat Model



- Employee Data Unencrypted at Rest
- Authentication data is using reversible encryption
- Authentication requests are not encrypted in transit
- Sensitive data is encrypted using DES algorithm

Completed Threat Analysis

What Type of Attack Caused the Login Alerts?

Man in the Middle (MitM)

What Proves Your Theory?

There is lack of encryption between the client and the application. A malicious actor is sniffing traffic and intercepting the requests with a valid username/password in the request. Additionally, the logs show successful login attempts from the expected IP, but also a different location at the same time.

Who is the Most Likely Threat Actor?

Internal User

What Proves Your Theory?

The IP address of the unexpected login matches that of an internal user. Additionally, there was no data leaked from the company, and no data changed. Just data accessed that the legitimate user typically doesn't access.



Section Two: Vulnerability Analysis



Employee Data Unencrypted at Rest

Discovery

During threat modeling, the Site Reliability Engineering (SRE) team confirmed that the database is on a server that does not have encryption at rest.

Why is this an issue?

[Explain why it is considered a vulnerability]

Result if the vulnerability is exploited:

[Describe the potential result of an exploitation]



Authentication Data Stored Using Reversible Encryption

Discovery

During threat modeling, the Database Administrators (DBA) team confirmed that the database is storing authentication data (credentials) encrypted.

Why is this an issue?

[Explain why it is considered a vulnerability]

Result if the vulnerability is exploited:

[Describe the potential result of an exploitation]



Authentication Requests are Unencrypted in Transit

Discovery

During threat modeling, the security team confirmed that authentication requests are being transmitted in plaintext.

Why is this an issue?

[Explain why it is considered a vulnerability]

Result if the vulnerability is exploited:

[Describe the potential result of an exploitation]



DES Algorithm in Use

Discovery

While conducting threat modeling, the security team identified sensitive data being stored using the Data Encryption Standard (DES) algorithm.

Why is this an issue?

[Explain why it is considered a vulnerability]

Result if the vulnerability is exploited:

[Describe the potential result of an exploitation]



Optional Task

Examine the threat model diagram from Section 1 and answer:

1. What non-encryption issues can you identify?
2. What recommendation would you give to solve those issues?
3. Why do you recommend those solutions?

1. *[Issue 1 Here]*
2. *[Issue 2 Here]*
3. *[Add more issues as necessary]*



Section Three: Risk Analysis



Risk Evaluation and Formula

Provide a rank for each risk (**1 is most dangerous, 4 is least dangerous**) and then provide the formula you used to calculate the rank.

<i>Risk</i>	<i>Rank</i>
Unencrypted at Rest	
Reversible Encryption	
Unencrypted in Transit	
Outdated Algorithm	

Provide the formula you used for the ranking:

[Write down the formula here.]



Risk Rationale

Provide the ranking calculation and justify the ranking assigned to each vulnerability.

#1 risk: *[Write the name of the #1 Risk]*

Provide your calculation of this risk:

[Write the ranking calculation you used here]

Justify your ranking of the vulnerability:

[Write your justification here.]

#2 risk: *[Write the name of the #2 Risk]*

Provide your calculation of this risk:

[Write the ranking calculation you used here]

Justify your ranking of the vulnerability:

[Write your justification here.]



Risk Rationale

Provide the ranking calculation and justify the ranking assigned to each vulnerability.

#3 risk: *[Write the name of the #3 Risk]*

Provide your calculation of this risk:

[Write the ranking calculation you used here]

Justify your ranking of the vulnerability:

[Write your justification here.]

#4 risk: *[Write the name of the #4 Risk]*

Provide your calculation of this risk:

[Write the ranking calculation you used here]

Justify your ranking of the vulnerability:

[Write your justification here.]



Section Four: Mitigation Plan



Employee Data Unencrypted at Rest

What is Your Recommended Mitigation Plan?

[Write your answer here.]

Why Did you Recommend This Course of Action?

[Write your answer here.]



Authentication Data Stored Using Reversible Encryption

What is Your Recommended Mitigation Plan?

[Write your answer here.]

Why Did you Recommend This Course of Action?

[Write your answer here.]



Authentication Requests are Unencrypted in Transit

What is Your Recommended Mitigation Plan?

[Write your answer here.]

Why Did you Recommend This Course of Action?

[Write your answer here.]



DES Algorithm in Use

What is Your Recommended Mitigation Plan?

[Write your answer here.]

Why Did you Recommend This Course of Action?

[Write your answer here.]



Security Audit

The audit team has been made aware of the systemic issue and wants to ensure your recommendations are followed. What steps can the audit team take?

[Write your answer here.]



Optional Task

**Create an architecture diagram of a secure system.
Image of your secure architecture:**



Optional Task

Additional Steps Would You Recommend to Prevent the Attack as well as Future Issues:

[Write your answer here.]